INFORME PROFESIONAL DE PENTESTING — INSECUR S.A.

6. PARTE II: PLANTILLA DE INFORME

6.1. Datos generales

- **Cliente:** INSECUR S.A.
- **Contratista (alumno/a):** Mateo Di Leo Blas
- **Username TryHackMe:** mateodileoblas
- **Email institucional:** mateodileoblas@gmail.com
- **Sala de elección (Nivel 2):** N/A (Nivel 1 Completado)
- **Branch en GitHub:** dileoblas-mateo
- **Fecha de inicio:** 06/10/2026
- **Fecha de cierre:** 08/10/2026

6.2. Pre-pentesting

Alcance del trabajo

El alcance del presente análisis de seguridad se limita estrictamente a las instancias de laboratorio asignadas en la plataforma TryHackMe dentro del marco académico:

- **Incluido en el alcance:**
- Sala Nivel 1: Pentesting Fundamentals
- Sala Nivel 1: Basic Pentesting (IP asignada en la sesión)
- **Excluido del alcance:**
- Cualquier otra infraestructura de TryHackMe, redes de terceros o sistemas reales de INSECUR S.A. fuera de las salas autorizadas.

Reglas de Enfrentamiento (ROE)

1. Se prohíbe el uso de ataques de Denegación de Servicio (DoS/DDoS) o técnicas destructivas que afecten la estabilidad de la plataforma.
2. Todas las actividades de recolección de información, escaneo y explotación deben realizarse únicamente dentro de los segmentos de red asignados por la VPN de TryHackMe (`tun0`).
3. Cualquier credencial, clave privada o secreto obtenido debe ser tratado con confidencialidad y documentado en el informe tras aplicar la redacción correspondiente.

Autorización

Se cuenta con la autorización explícita expresada en la carta de contratación de INSECUR S.A. y el marco académico de la cátedra de Seguridad Aplicada a Sistemas de Información para la ejecución de pruebas de penetración sobre los entornos asignados.

Metodología utilizada

Se ha aplicado la metodología estándar **PTES (Penetration Testing Execution Standard)**, estructurada en las fases de Pre-engagement, Reconocimiento, Escaneo, Enumeración, Explotación, Post-explotación y Reporte. Esta metodología garantiza un enfoque metódico, reproducible y profesional.

6.3. Durante: Hallazgos por fase

Hallazgo 1 (H-01): Exposición de carpetas web y enumeración de usuarios vía SMB

- **ID del hallazgo:** H-01
- **Fase:** Escaneo / Enumeración
- **Descripción:** Se detectaron servicios SMB y HTTP expuestos. La enumeración web con `gobuster` reveló recursos ocultos y la enumeración SMB permitió identificar cuentas de usuarios del sistema (`jan`, `kay`) sin requerir autenticación previa.
- **Componente afectado:** Servidor web Apache / Servicio Samba SMB
- **Categoría (OWASP / CWE):** OWASP A05:2021 – Configuración de Seguridad Defectuosa / CWE-200
- **CVSS estimado:** Medio
- **Evidencia (captura / comando):** `gobuster dir -u http://<IP> -w /usr/share/wordlists/dirb/common.txt` y `enum4linux` / `nmap`
- **Herramienta utilizada:** Gobuster, Nmap
- **Impacto en la Tríada CIA:** Confidencialidad
- **Salvaguarda propuesta:** Deshabilitar el acceso anónimo y la enumeración de usuarios en Samba (`restrict anonymous = 2`), e implementar restricciones de acceso a directorios web sensibles.
- **Riesgo residual tras aplicar:** Bajo

Hallazgo 2 (H-02): Frase de paso débil en clave privada SSH y escalada de privilegios

- **ID del hallazgo:** H-02
- **Fase:** Explotación / Post-explotación
- **Descripción:** Tras ingresar al sistema, se localizó una clave privada RSA (`id_rsa`) perteneciente al usuario `kay`. Mediante fuerza bruta con `john` y el diccionario `rockyou.txt`, se obtuvo la frase de paso débil (`beeswax`), permitiendo la suplantación de identidad del usuario y el acceso a información confidencial (`pass.bak`).
- **Componente afectado:** Servicio OpenSSH / Cuenta de usuario `kay`
- **Categoría (OWASP / CWE):** OWASP A07:2021 – Fallos de Identificación y Autenticación / CWE-521
- **CVSS estimado:** Alto
- **Evidencia (captura / comando):** `john --wordlist=rockyou.txt hash.txt` resultando en la clave `beeswax`
- **Herramienta utilizada:** John the Ripper, SSH
- **Impacto en la Tríada CIA:** Confidencialidad e Integridad
- **Salvaguarda propuesta:** Establecer una política estricta de contraseñas complejas para claves SSH (mínimo 16 caracteres alfanuméricos) y migrar a claves Ed25519.
- **Riesgo residual tras aplicar:** Bajo

6.4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	0	-
Alto	1	H-02
Medio	1	H-01
Bajo	0	-
Total	**2**	**H-01, H-02**

6.5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

1. Restringir la enumeración anónima en los servicios SMB editando `/etc/samba/smb.conf`.
2. Forzar la rotación de claves SSH y exigir frases de paso (*passphrases*) complejas que no figuren en diccionarios conocidos.
3. Eliminar archivos de copia de seguridad conteniendo credenciales en texto plano (`pass.bak`) de los directorios personales de los usuarios.

Recomendaciones administrativas (políticas y procesos)

1. Implementar una Política de Contraseñas y Gestión de Claves Criptográficas obligatoria para todo el personal técnico de INSECUR S.A.
2. Realizar auditorías técnicas y escaneos de vulnerabilidades periódicos sobre los activos internos de la empresa.

7. PARTE III: PROTOCOLO DE CONTINGENCIA

Escenario de falla

Bloqueo de cuentas de usuario o interrupción del servicio OpenSSH/SMB durante las pruebas de seguridad o la aplicación de parches en producción.

Impacto sobre la continuidad del negocio

Afectación temporal en el acceso remoto de los administradores y retraso en la transferencia interna de archivos, con un tiempo estimado de interrupción inferior a 1 hora si se aplica contención rápida.

Plan de respuesta

1. **Activación:** Se detecta la indisponibilidad del servicio mediante monitoreo de red o fallos de autenticación persistentes.
2. **Contención (primeros 15 minutos):** Aislar el puerto afectado temporalmente y verificar que no existan intentos de intrusión no autorizados en curso.
3. **Recuperación:** Restaurar las configuraciones previas de los servicios (`/etc/ssh/sshd_config`, `/etc/samba/smb.conf`) desde la copia de respaldo más reciente y reiniciar los demonios correspondientes.
4. **Comunicación:** Informar al equipo de TI e Infraestructura de INSECUR S.A. sobre el incidente y el estado de la restauración.
5. **Post-mortem:** Documentar la causa raíz de la falla y actualizar los procedimientos de despliegue.

RTO y RPO estimados

- **RTO (Recovery Time Objective):** 30 minutos
- **RPO (Recovery Point Objective):** 0 horas

8. ANEXOS

Anexo A: Bitácora de comandos

Archivos adjuntos en la carpeta `bitacora/` del repositorio.

Anexo B: Capturas de pantalla

Imágenes organizadas en la carpeta `evidencias/` por cada fase del pentesting.

Anexo C: Hashes de las flags obtenidas

- **H-01 (Verificación):** `[Hash SHA-256 generado]`
- **H-02 (Verificación):** `[Hash SHA-256 generado]`

Anexo D: Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma del estudiante: Mateo Di Leo Blas

Fecha: 08/10/2026